

Développement des systèmes d'IA : les recommandations de la CNIL pour respecter le RGPD

22 juillet 2025

*La CNIL a publié ses premières recommandations sur l'application du RGPD au développement des systèmes d'**intelligence artificielle** pour aider les professionnels à concilier innovation et respect des droits des personnes. Voici ce qu'il faut en retenir.*

Les concepteurs et développeurs de systèmes d'**intelligence artificielle** font souvent remonter à la CNIL que l'application du RGPD leur pose des difficultés, notamment pour l'entraînement des modèles.

L'idée reçue selon laquelle le RGPD empêcherait l'innovation en intelligence artificielle en Europe est fausse. En revanche, il faut avoir conscience que les bases d'entraînement comprennent parfois des « données personnelles », des informations sur des personnes réelles. L'utilisation de ces données fait courir des risques aux personnes, qu'il faut prendre en compte afin de développer des systèmes d'IA dans des conditions qui respectent les droits et libertés des personnes, et notamment leur droit à la vie privée.

En complément de cette fiche, la CNIL met à la disposition des professionnels concernés un document contenant une liste des points à vérifier.

[> Consulter les fiches pratiques](#)

[> Consulter la liste de vérification](#)

Périmètre des recommandations

Quels sont les systèmes d'IA concernés ?

Ces recommandations concernent le développement de **systèmes d'IA impliquant un traitement de données personnelles** (pour plus d'informations sur le cadre juridique, voir la [fiche n°1](#)). En effet, l'entraînement des systèmes d'IA nécessite régulièrement l'utilisation d'importants volumes d'informations sur des personnes physiques, qu'on nomme « données personnelles ».

Sont concernés :

- les systèmes fondés sur l'**apprentissage automatique** (*machine learning*) ;
- les systèmes dont l'usage opérationnel est défini dès la phase de développement et les systèmes à usage général qui pourront être utilisés pour nourrir différentes applications (« *general purpose AI* »).
- Les systèmes dont l'apprentissage est réalisé « une fois pour toutes » ou de façon continue, par exemple en utilisant des données d'utilisation pour son amélioration.

Quelles sont les étapes concernées ?

Ces recommandations concernent la **phase de développement de systèmes d'IA, et non celle de déploiement**.

La phase de développement comprend toutes les étapes préalables au déploiement du **système d'IA** à savoir : la conception du système, la constitution de la base de données et l'apprentissage.

[*Consulter la version PDF*](#)

Comment ces recommandations s'articulent-elles avec le règlement européen sur l'IA ?

Les recommandations formulées prennent en considération le nouveau règlement européen sur l'**intelligence artificielle** adopté à l'été 2024. En effet, **lorsque des données personnelles sont utilisées** pour le développement d'un système d'IA, **le RGPD et le règlement sur l'IA s'appliquent tous les deux**. Les recommandations de la CNIL ont donc été élaborées pour compléter ces dernières de manière cohérente sur le volet relatif à la protection des données.

- [Pour plus d'informations, voir la fiche n°0](#)

1ère étape : Définir un objectif (finalité) pour le système d'IA

Le principe

Un **système d'IA** reposant sur l'exploitation de données personnelles doit être développé avec une « finalité », c'est-à-dire un objectif bien défini.

Cela permet de cadrer et de limiter les données personnelles que l'on va pouvoir utiliser pour l'entraînement, afin de ne pas stocker et traiter des données inutiles.

Cet objectif doit être déterminé, soit établi dès la définition du projet. Il doit également être explicite, autrement dit connu et compréhensible. Il doit enfin être légitime, c'est-à-dire compatible avec les missions de l'organisme.

Il est parfois objecté que l'exigence de définir une finalité est incompatible avec l'entraînement d'IA, qui peut développer des caractéristiques non anticipées. La CNIL estime qu'il n'en est rien et que l'exigence de définition d'une finalité doit être adaptée au contexte de l'IA, sans disparaître pour autant, comme le montrent les exemples qui suivent.

En pratique

Il existe trois types de situations.

Vous savez clairement quel sera l'usage opérationnel de votre système d'IA

Dans ce cas, cet objectif sera la finalité de la phase de développement comme de la phase de déploiement et d'utilisation.

Exemple : Un organisme constitue une base de données composée de photos de rames de trains en service – c'est-à-dire avec des personnes présentes – afin d'entraîner un **algorithme** pour mesurer l'affluence et la fréquentation des trains à quai dans les gares. La finalité en phase de développement est déterminée, explicite et légitime au regard de l'usage opérationnel identifié.

Cela est toutefois plus complexe lorsque vous développez **un système d'IA à usage général** qui pourra être utilisé dans divers contextes et applications ou lorsque votre **système est développé à des fins de recherche scientifique**.

Pour les systèmes d'IA à usage général

Exemple : Un organisme peut constituer une base de données pour l'entraînement d'un modèle de classification d'images (personnes, véhicules, aliments, etc.) et le rendre publiquement accessible, sans qu'aucun usage opérationnel spécifique ne soit prévu lors du développement du modèle.

Vous ne pouvez pas définir la finalité de manière trop générale comme, par exemple, « le développement et amélioration d'un système d'IA ». Il vous faudra être plus précis et faire référence :

- **au « type » de système développé**, comme, par exemple, le développement d'un **modèle de langage** de grande taille, d'un système de vision par ordinateur ou encore d'un système d'IA générative d'images, de vidéos, de sons, de codes informatiques, etc. ;
- **aux fonctionnalités et capacités techniquement envisageables.**

Bonne pratique :

Vous pouvez donner encore plus de précisions quant à l'objectif poursuivi, par exemple en déterminant :

- les capacités prévisibles les plus à risque ;
- les fonctionnalités exclues par conception ;
- les conditions d'utilisation du système d'IA : les cas d'usage connus de la solution ou encore les modalités d'utilisation (diffusion du modèle en open source, commercialisation, mise à disposition en **SaaS** ou par API, etc.).

Pour les systèmes d'IA développés à des fins de recherche scientifique

Exemple : Pourrait être considéré comme poursuivant des fins de recherche scientifique le développement d'un système d'IA pour une preuve de concept destinée à démontrer la robustesse d'un **apprentissage automatique** nécessitant moins de données d'entraînement, dans une démarche scientifique documentée ayant vocation à faire l'objet d'une publication.

Vous pouvez définir un objectif moins détaillé, compte tenu des difficultés à le définir précisément dès le début de vos travaux. Vous pouvez alors fournir des informations complémentaires pour préciser cet objectif à mesure que votre projet progresse.

- [Pour plus d'informations, voir la fiche n°2](#)

2e étape : Déterminer vos responsabilités

Le principe

Si vous utilisez des données personnelles pour le développement de systèmes d'IA, vous devez déterminer votre responsabilité au sens du RGPD. Vous pouvez être :

- **Responsable de traitement (RT)** : vous déterminez les objectifs et les moyens, c'est-à-dire lorsque vous décidez du « pourquoi » et du « comment » de l'utilisation de données personnelles. Si un ou plusieurs autres organismes décident avec vous de ces éléments, vous serez responsables conjoints du

traitement et devrez définir vos obligations respectives (par exemple par le biais d'un contrat).

- **Sous-traitant (ST)** : vous traitez des données pour le compte d'un donneur d'ordre qui est le « responsable du traitement ». Dans ce cas, ce dernier doit s'assurer que vous respectez le RGPD et que vous ne traitez les données que sur ses instructions : la loi prévoit alors la conclusion d'[un contrat de sous-traitance](#).

En pratique

Le règlement européen sur l'IA définit plusieurs rôles :

- **le fournisseur de système d'IA** qui développe ou fait développer un système et qui le met sur le marché ou le met en service sous son propre nom ou sa propre marque, à titre payant ou gratuit ;
- **les importateurs, distributeurs et les utilisateurs (également appelés déployeurs)** de ces systèmes.

Votre degré de responsabilité dépend d'une analyse au cas par cas

Par exemple :

- Si vous êtes un fournisseur à l'initiative du développement d'un système d'IA et que vous constituez la base de données d'apprentissage à partir de données que vous avez sélectionnées pour votre propre compte, vous **pouvez être qualifié de responsable de traitement**.
- Si vous constituez la base de données d'apprentissage d'un système d'IA avec d'autres responsables de traitement pour un objectif que vous avez défini ensemble, **vous pouvez être qualifiés de responsables conjoints du traitement**.
- Si vous êtes un fournisseur de système d'IA, **vous pouvez être sous-traitant si vous développez un système pour le compte d'un de vos clients**. Le client sera responsable du traitement s'il détermine l'objectif mais aussi les moyens, les techniques à utiliser. S'il ne vous donne qu'un objectif à atteindre et que c'est vous qui concevez le système d'IA, **vous êtes responsable du traitement**.
- Si vous êtes un fournisseur de système d'IA vous pouvez faire appel à un prestataire pour collecter et traiter les données selon vos instructions. **Le prestataire sera votre sous-traitant**. C'est le cas par exemple du prestataire qui doit constituer une base de données d'apprentissage pour un fournisseur de système d'IA qui lui indique précisément comment elle doit être élaborée.
- [Pour plus d'informations, voir la fiche n°3](#)

Pour la suite :

- Si vous êtes responsable de traitement, toutes les étapes suivantes vous concernent directement, c'est vous qui êtes tenus d'en assurer le respect.

- Si vous êtes sous-traitant, vos principales obligations sont les suivantes :
 - Vous assurer qu'un contrat de sous-traitance de données personnelles a été conclu et qu'il est conforme à la réglementation ;
 - Respecter strictement les instructions du responsable de traitement et ne pas utiliser les données personnelles pour autre chose ;
 - Assurer rigoureusement la sécurité des données que vous traitez ;
 - Évaluer à votre niveau le respect du RGPD (cf. les étapes suivantes) et alerter le responsable de traitement s'il vous semble qu'il y a un problème.
-

3e étape : Définir la « base légale » qui vous autorise à traiter des données personnelles

Le principe

Le développement de systèmes d'IA contenant des données personnelles devra disposer d'une [base légale](#) qui vous autorise à traiter ces données. Le RGPD liste 6 bases légales possibles : le consentement, le respect d'une obligation légale, l'exécution d'un contrat, l'exécution d'une mission d'intérêt public, la sauvegarde des intérêts vitaux, la poursuite d'un intérêt légitime.

Selon la **base légale** retenue, vos obligations et les droits des personnes pourront varier, c'est pour cela qu'il est important de la déterminer en amont et de l'indiquer dans la politique de confidentialité des données.

En pratique

Identifier la base légale adéquate

Vous devez vous interroger sur **la base légale la plus adaptée à votre situation**.

Si vous collectez les données directement auprès des personnes et qu'elles sont libres d'accepter ou de refuser sans subir de préjudice (tel que le fait de renoncer au service), le consentement est souvent la base légale la plus appropriée. Selon la loi, il doit **être libre, spécifique, éclairé et univoque**.

Recueillir le consentement est cependant souvent impossible en pratique. Par exemple, lorsque vous collectez des données accessibles en ligne ou réutilisez une base de données ouverte (*open source*), sans contact direct avec les personnes concernées, d'autres bases légales seront, généralement, plus adaptées :

- **Les acteurs privés** devront analyser s'ils respectent les conditions pour se fonder sur l'intérêt légitime. Ils doivent pour cela justifier de trois conditions :
 - **L'intérêt poursuivi est légitime** c'est-à-dire légal, défini de manière précise et réel ;
 - il faut pouvoir établir que les données personnelles sont vraiment nécessaires à l'entraînement du système, parce qu'il n'est pas possible de n'utiliser que des données ne se rapportant pas à des

personnes physiques ou des données anonymisées ;

- l'utilisation de ces données personnelles ne doit pas porter une « atteinte disproportionnée » à la vie privée des personnes. Cela s'apprécie au cas par cas, en fonction de ce que révèlent les données utilisées, qui peut être plus ou moins privé ou sensible, et de ce qui est fait des données ;
- **Les acteurs publics** doivent vérifier si le traitement s'inscrit dans leur mission d'intérêt public telle que prévue par un texte (par exemple une loi, un décret, etc.) et s'il y contribue de manière pertinente et appropriée.

Exemple : le pôle d'expertise de la régulation numérique (PEReN) est autorisé sur ce fondement à réutiliser des données publiquement accessibles pour réaliser des expérimentations ayant notamment pour objet de concevoir des outils techniques destinés à la régulation des opérateurs de plateformes en ligne.

Les bases légales du contrat et de l'obligation légale peuvent être plus exceptionnellement mobilisées, si vous démontrez en quoi votre traitement est nécessaire pour répondre à l'exécution du contrat ou de mesures précontractuelles ou à une obligation légale (suffisamment précise) à laquelle vous êtes soumis.

- [Pour plus d'informations, voir la fiche n°4](#)

Mobiliser l'intérêt légitime

L'intérêt légitime est une des bases légales les plus couramment utilisées pour le développement de systèmes d'IA, surtout par les organismes privés. L'intérêt correspond au bénéfice que le **responsable de traitement** ou des tiers tirent du développement du **système d'IA**.

Le recours à l'intérêt légitime est soumis à trois conditions :

1. L'intérêt poursuivi doit être légitime

L'intérêt poursuivi doit être légal au regard du droit (incluant les autres réglementations que le RGPD, dont le RIA) et déterminé de façon suffisamment claire et précise. Il doit avoir un lien avec votre mission et activité.

Sont **a priori considérés comme légitimes** les intérêts suivants : mener des travaux de recherche scientifique, faciliter l'accès public à certaines informations, proposer un service d'agent conversationnel d'assistance aux utilisateurs, développer un système d'IA de détection de contenus et comportements frauduleux, etc.

Un intérêt commercial constitue un intérêt légitime pour autant qu'il ne soit pas contraire à la loi et que le traitement soit nécessaire et proportionné.

2. Le traitement doit être nécessaire

L'intérêt poursuivi ne peut pas être atteint par des moyens moins intrusifs pour la vie privée et le développement du système est bien nécessaire pour atteindre l'objectif donné. La nécessité du traitement s'examine donc en lien avec le principe de **minimisation** (voir « 5^{ème} étape : minimiser les données personnelles que j'utilise »).

3. L'utilisation des données ne porte pas une « atteinte disproportionnée » à la vie privée des personnes

Le responsable de traitement doit mettre en balance les bénéfices attendus, de son point de vue, de son traitement et les impacts sur les individus concernés. Si nécessaire, il faut mettre en place des garanties limitant ces risques protégeant les droits et libertés des personnes.

Les attentes raisonnables des personnes à prendre en compte

L'usage de leurs données ne doit pas surprendre les personnes. Vous devez prendre en compte plusieurs éléments lorsque vous souhaitez recourir à la base légale de l'intérêt légitime pour traiter les données :

- **pour les données collectées auprès des personnes** : la relation entre vous et la personne, le contexte, la nature du service, les paramètres de confidentialité et le fait que le traitement de données ne concerne que le service fourni à la personne ou sert à l'amélioration du service dans sa globalité ;
- **pour la réutilisation des données publiées sur internet** : le caractère publiquement accessible des données, le contexte et la nature des sites web sources (réseaux sociaux, forums en ligne, sites de diffusion de jeux de données, etc.), le type de publication ou encore la relation entre la personne concernée et l'organisme. Le traitement ne pourra pas entrer dans les attentes raisonnables des personnes si vous n'excluez pas de la collecte les sites qui ont mis des restrictions (CGU, fichiers robots.txt, CAPTCHA).

À noter : les personnes peuvent avoir conscience que certaines des données qu'elles publient en ligne sont susceptibles d'être consultées, collectées et réutilisées par des tiers. Elles ne peuvent néanmoins pas s'y attendre dans toutes les situations et pour tous les types de données accessibles en ligne les concernant.

Les garanties permettant de limiter les impacts du traitement

Des garanties peuvent permettre de limiter la collecte ou la conservation de données personnelles, d'assurer le contrôle des personnes sur leurs données, de limiter les risques en phase d'utilisation, etc. Elles doivent être adaptées aux risques tout au long de la phase de développement. Vous devez donc déterminer celles qui sont les plus pertinentes dans votre cas. Par exemple, il peut s'agir :

- de prévoir l'anonymisation à bref délai des données collectées ou, à défaut, leur pseudonymisation ;
 - d'adopter des mesures pour limiter les risques de **mémorisation** des modèles d'IA et ainsi réduire les possibilités d'extraction ou de **régurgitation** ;
 - de mettre en œuvre un droit d'opposition discrétionnaire et préalable ;
 - de prévoir un droit discrétionnaire à l'effacement des données contenues dans la base de données d'entraînement ;
 - de mettre en place des mesures pour permettre l'identification des personnes lorsqu'elles exercent leurs droits ;
 - de faciliter la notification des droits et communiquer largement sur les mises à jour des bases de données ou des modèles, etc.
- [Pour plus d'informations, voir la fiche n° 8](#)
-

3ème étape (bis) : Adapter les garanties au moissonnage des données

Le principe

Le moissonnage de données (ou *web scraping*) n'est pas, en lui-même, interdit par le RGPD. Si vous êtes un organisme privé, vous pouvez y avoir recours sur la **base légale** de l'intérêt légitime sous réserve de mettre en œuvre des garanties adaptées.

En pratique

Respecter le principe de minimisation

À cette fin, vous devez :

- **Définir à l'avance ce que vous recherchez** : il faut décider clairement quelles catégories de données sont utiles avant de commencer la collecte.
- **Ne pas collecter plus que nécessaire** : il faut exclure la collecte de certaines catégories de données, par filtrage ou par exclusion de certains types de sites, notamment les **données sensibles** si leur collecte n'est pas pertinente pour le traitement effectué.
- **Supprimer les données inutiles** : si vous récupérez par erreur des données qui ne sont pas pertinentes, il faut les supprimer immédiatement.
- **Respecter les sites qui refusent la collecte automatique** : vous ne devez pas récupérer de données sur les sites qui s'opposent au moissonnage de leur contenu au moyen de protections techniques (comme les CAPTCHA ou les fichiers robots.txt).

Respecter les attentes raisonnables

Vous devez tenir compte du caractère publiquement accessible des données, de la nature des sites web source (réseaux sociaux, forums en ligne, etc.), du type de publication (par exemple un article publié sur un blog librement accessible ou une publication restreinte), etc.

Par ailleurs, la pratique du moissonnage ne rentre pas dans les attentes raisonnables des personnes lorsque le site en question s'oppose au moissonnage de son contenu au moyen de protection techniques (comme les CAPTCHA ou les fichiers robots.txt).

Garanties supplémentaires

Vous pouvez mettre en place des mesures supplémentaires en fonction de l'usage prévu de votre **système d'IA**. La mise place d'une ou plusieurs de ces mesures peut être nécessaire en fonction des risques que présente le traitement :

- Établir une liste d'exclusion de sites par défaut car contenant des données particulièrement sensibles (forums de santé, etc.) ;
 - Exclure les sites qui s'opposent au moissonnage de leur contenu par le biais de mesures techniques ou juridiques (par exemple les conditions générales d'utilisation) ;
 - Limiter la collecte aux données librement accessibles (sans besoin de création de compte) pour lesquelles les personnes ont conscience de leur caractère public ;
 - Informer les personnes aussi largement que possible (articles en ligne, sur les comptes de réseaux sociaux, etc.) ;
 - Prévoir un **droit d'opposition** discrétionnaire et préalable, en amont de la collecte avec un délai raisonnable avant entraînement d'un modèle ;
 - Anonymiser ou pseudonymiser les données juste après leur collecte et prévenir tout recoupement de données à partir des identifiants des personnes.
 - [Pour plus d'informations, voir la fiche n° 8 bis](#)
-

4e étape : Vérifier si je peux réutiliser certaines données personnelles

Le principe

Si vous envisagez de réutiliser une base de données personnelles, il faut s'assurer que c'est légal. Cela dépend des modalités de collecte et de la source des données en cause. **Vous devez, en tant que responsable de traitement (voir la partie « déterminer vos responsabilités »), effectuer certaines vérifications complémentaires afin de garantir que cette utilisation est légale.**

En pratique

Les règles vont dépendre des situations.

Le fournisseur réutilise des données qu'il a lui-même déjà collectées

Vous pouvez vouloir réutiliser les données que vous avez initialement collectées pour un autre objectif. Dans ce cas, si vous n'aviez pas prévu et informé les personnes concernées de cette réutilisation, vous devez vérifier que ce nouvel usage est **compatible** avec l'objectif initial, sauf si vous êtes autorisé par les personnes concernées (elles ont consenti) ou par un texte (par exemple une loi, un décret etc.).

Vous devez effectuer ce qu'on appelle un « test de compatibilité », qui doit prendre en compte :

- l'existence d'un lien entre l'objectif initial et celui de constitution de base de données pour l'apprentissage d'un **système d'IA** ;

- le contexte dans lequel les données personnelles ont été collectées ;
- le type et la nature des données ;
- les éventuelles conséquences pour les personnes concernées ;
- l'existence de garanties appropriées (par exemple la pseudonymisation des données).

À noter : si vous souhaitez réutiliser des données dans un objectif de production de statistiques ou de recherche scientifique, le traitement est présumé compatible avec l'objectif initial. **Aucun test de compatibilité n'est donc nécessaire dans ce cas.**

Le fournisseur réutilise des données publiquement accessibles (*open source*)

Dans ce cas, vous devez vous assurer que vous n'êtes pas en train de réutiliser une base de données dont la constitution était manifestement illicite (par exemple, provenant d'une fuite de données). **Une analyse au cas par cas doit être effectuée.**

La CNIL recommande aux réutilisateurs de vérifier et de documenter (par exemple, dans l'analyse d'impact sur la protection des données) les éléments suivants :

- la description de la base de données mentionne leur source ;
- la constitution ou la diffusion de la base de données **ne résulte pas manifestement d'un crime ou d'un délit ou a fait l'objet d'une condamnation ou d'une sanction publique** de la part d'une autorité compétente qui a impliqué une suppression ou une interdiction d'exploitation ;
- il n'y a **pas de doutes flagrants sur le fait que la base de données est licite** en s'assurant en particulier que les conditions de collecte des données soient suffisamment documentées ;
- la base de données ne contient **pas de données sensibles** (données de santé ou révélant des opinions politiques par exemple) **ou de données d'infraction** ou, si elle en contient, il est recommandé de mener des vérifications supplémentaires pour s'assurer que ce traitement est licite.

L'organisme qui a mis en ligne la base de données est censé s'être assuré que cette publication respectait le RGPD, et en est responsable. En revanche, vous n'avez pas à vérifier que les organismes qui ont constitué et diffusé la base de données aient respecté toutes les obligations prévues par le RGPD : la CNIL estime que les quatre vérifications mentionnées ci-dessus suffisent généralement à permettre la réutilisation de la base pour l'entraînement d'un système d'IA, à condition de respecter les autres recommandations de la CNIL. Si vous recevez des informations, notamment de personnes dont les données sont contenues dans la base, qui mettent en lumière des problèmes de licéité de la base de données utilisées, vous devrez investiguer davantage.

Le fournisseur réutilise des données acquises auprès d'un tiers (courtiers en données ou *data brokers*, etc.)

Pour le tiers qui partage des données personnelles, parfois contre rémunération, il existe deux types de situations.

Soit le tiers a collecté les données dans l'objectif de constituer une base de données pour l'apprentissage de système d'IA. Il doit s'assurer de la conformité du traitement de transmission des données au regard du RGPD (définition d'un objectif explicite et légitime, exigence d'une **base légale**, information des personnes et gestion de l'exercice de leurs droits, etc.).

Soit le tiers n'a pas initialement collecté les données pour cet objectif. Il doit alors s'assurer que la transmission de ces données poursuit un objectif compatible avec celui ayant justifié leur collecte. **Il devra donc réaliser le « test de compatibilité » présenté plus haut.**

Le réutilisateur des données a, quant à lui, plusieurs obligations :

- Il doit s'assurer qu'il n'est pas en train de réutiliser une base de données manifestement illicite en faisant les mêmes vérifications que celles énoncées dans la partie ci-dessus. La conclusion d'un accord entre le détenteur initial des données et le réutilisateur est recommandée afin de faciliter ces vérifications.
- En plus de ces vérifications, il doit s'assurer de sa propre conformité au RGPD dans le traitement de ces données.
- [Pour plus d'informations, voir la fiche n°4.](#)

5e étape : minimiser les données personnelles que j'utilise

Le principe

Les données personnelles collectées et utilisées doivent être **adéquates, pertinentes et limitées à ce qui est nécessaire** au regard de l'objectif défini : c'est le principe de [minimisation des données](#). Vous devez respecter ce principe et l'appliquer de manière rigoureuse lorsque les données traitées sont sensibles (données concernant la santé, données relatives à la vie sexuelle aux opinions religieuses ou politiques, etc.).

En pratique

La méthode à employer

Vous devez privilégier la technique permettant d'atteindre le résultat recherché (ou du même ordre) **en utilisant le moins de données personnelles possible**. En particulier, le recours à l'apprentissage profond ne doit donc pas être systématique.

Le choix du protocole d'apprentissage utilisé peut, par exemple, permettre de limiter l'accès aux données aux seules personnes habilitées, ou encore de ne donner accès qu'à des données chiffrées.

La sélection des données strictement nécessaires

Le principe de **minimisation** n'interdit pas d'entraîner un **algorithme** avec des volumes très importants de données, mais implique :

- d'avoir une réflexion en amont afin de recourir aux seules données personnelles utiles au développement du système ; et
- à mettre, par la suite, en œuvre les moyens techniques pour ne collecter que celles-ci.

La validité des choix de conception

Afin de valider les choix de conception, il est recommandé à titre de bonne pratique de :

- **mener une étude pilote**, c'est-à-dire réaliser une expérimentation à petite échelle. Des données fictives, synthétiques, anonymisées peuvent être utilisées à cette fin ;
- **interroger un comité éthique** (ou un « référent éthique »). Ce comité doit garantir que les enjeux en matière d'éthique et de protection des droits et libertés des personnes sont bien pris en compte. Il peut ainsi formuler des avis sur tout ou partie des projets, outils, produits, etc. de l'organisme susceptibles de poser des problématiques éthiques.

L'organisation de la collecte

Vous devez vous assurer que les données collectées sont pertinentes compte tenu des objectifs poursuivis. Plusieurs étapes sont fortement recommandées :

- **Le nettoyage des données** : cette étape vous permet de constituer une base d'apprentissage de qualité et ainsi renforcer l'intégrité et la pertinence des données en réduisant les incohérences, et ainsi que le coût de l'apprentissage.
- **L'identification des données pertinentes** : cette étape vise à optimiser les performances du système tout en évitant les sous- et sur-apprentissage. En pratique, elle vous permet de vous assurer que certaines classes ou catégories inutiles pour la tâche visée ne sont pas représentées, que les proportions entre les différentes classes d'intérêt sont bien équilibrées, etc. Cette procédure vise également à identifier les données non pertinentes pour l'apprentissage (qui devront alors être supprimées de la base).
- La mise en œuvre de **mesures pour intégrer dès leur conception les principes de protection des données personnelles** : cette étape vous permet d'appliquer des transformations sur les données (telles que des mesures de généralisation et/ou de randomisation, anonymisation des données, etc.) pour limiter l'impact pour les personnes.
- **Le suivi et la mise à jour des données** : les mesures de minimisation pourraient devenir obsolètes au cours du temps. En effet, les données collectées pourraient perdre leurs caractères exact, pertinent, adéquat et limité, en raison d'une possible **dérive des données**, d'une mise à jour de celles-ci ou de l'évolution des techniques. Vous devrez donc conduire une analyse régulière pour assurer le suivi de la

base de données constituée.

- **La documentation des données** utilisées pour le développement d'un système d'IA : celle-ci vous permet de garantir la traçabilité des jeux de données utilisés que la grande taille peut rendre difficile. Vous devez tenir cette documentation à jour en fonction des modifications apportées à la base de données. La CNIL fournit [un modèle de documentation](#).
 - Pour plus d'informations, voir les fiches [n°6](#) et [n°7](#)
-

6e étape : Définir une durée de conservation

Le principe

Les données personnelles ne peuvent être conservées indéfiniment. Le RGPD vous impose de définir une durée au bout de laquelle les données doivent être supprimées ou, dans certains cas, archivées. **Vous devez déterminer cette durée de conservation en fonction de l'objectif** ayant conduit au traitement de ces données.

En pratique

Vous devez fixer une durée de conservation des données utilisées pour le développement du **système d'IA** :

- **Pour la phase de développement** : la conservation des données doit faire l'objet d'une planification en amont et d'un suivi dans le temps. Les personnes concernées doivent être informées de la durée de conservation des données (par exemple dans les [mentions d'information](#)) ;
- **Pour la maintenance ou l'amélioration du produit** : lorsque les données n'ont plus à être accessibles pour les tâches quotidiennes des personnes en charge du développement du système d'IA, elles doivent en principe être supprimées. Elles peuvent toutefois être conservées pour la maintenance du produit ou son amélioration si des garanties sont mises en œuvre (support cloisonné, restriction des accès aux seules personnes habilitées, etc.).

À noter : la conservation des données d'apprentissage peut permettre d'effectuer des audits et faciliter la mesure de certains biais. Dans ce cas, une conservation prolongée des données peut être justifiée, sauf si la conservation d'informations générales sur les données suffit (par exemple, la documentation réalisée sur le modèle proposé dans la section [Documentation](#), ou encore des informations sur la distribution statistique des données). Cette conservation doit être limitée aux données nécessaires, et s'accompagner de mesures de sécurité renforcées.

- [Pour plus d'informations, voir la fiche n°7](#)
-

7e étape : Informer les personnes

Le principe

Vous devez informer les personnes concernées afin qu'elles comprennent les usages qui seront faits de leurs données (pourquoi, comment, de quelle manière) et soient en mesure d'exercer leurs droits (droits d'opposition, d'accès, de rectification, etc.).

L'obligation d'information s'applique aux données collectées directement auprès des personnes concernées (dans le cadre de la fourniture d'un service, d'un contrat de prestation avec des acteurs volontaires, etc.) ou indirectement, notamment par moissonnage (*web scraping*).

En pratique

Garantir l'accessibilité de l'information

Vous devez vous assurer que l'information est **facilement accessible** :

- l'information individuelle peut figurer sur le formulaire utilisé pour collecter les données, via un message vocal pré-enregistré, etc. ;
- l'information générale peut prendre la forme de mentions d'information publiées sur votre site web.

Il est recommandé de respecter un **délai raisonnable** entre l'information des personnes de la collecte de données et l'entraînement du fait de la difficulté pour les personnes d'exercer leurs droits sur le modèle une fois celui-ci entraîné.

Garantir l'intelligibilité de l'information

Vous devez vous assurer que l'information est concise et claire. La complexité des systèmes d'**intelligence artificielle** ne doit pas empêcher la bonne compréhension de l'information par les personnes concernées.

Il est recommandé de détailler, par exemple au moyen de schémas, la manière dont les données sont utilisées lors de l'apprentissage, le fonctionnement du **système d'IA** développé, ainsi que la distinction qui doit être faite entre la base de données d'apprentissage, le modèle d'IA et les sorties du modèle.

À noter : les informations peuvent figurer dans les cartes de données, de modèles ou de systèmes (*AI dataset, model and system cards*), mais doivent ressortir clairement de ces documentations.

Choisir entre information individuelle et générale

L'information doit être **individuelle**, mais le RGPD prévoit des **exceptions** :

- L'intégralité des informations sur le traitement a déjà été fournie à la **personne concernée** (par exemple, par un tiers).
- L'information exigerait des **efforts disproportionnés**, en tenant compte des efforts à fournir (absence de moyens de contact, ancienneté des données, etc.) et du niveau d'atteinte portée à la vie privée. En particulier, l'information individuelle est souvent disproportionnée lors d'une collecte de données pseudonymisées par moissonnage (*web scraping*) puisque le fait de trouver les moyens de contacter les personnes peut supposer de collecter des données supplémentaires ou plus identifiantes.

Dans ce dernier cas, vous pouvez vous contenter de publier une **notice d'information générale** complète sur votre site internet.

À noter : l'article 53 du RIA prévoit l'obligation pour les fournisseurs de **modèles d'IA à usage général** de compléter un résumé public du contenu utilisé pour l'entraînement d'un système d'IA, sur la base d'un modèle fourni par le Bureau de l'IA. Ce résumé pourra contribuer à l'**information générale** sur les sources de données.

Les informations spécifiques à transmettre

Vous devez généralement fournir l'ensemble des informations prévues aux articles 13 et 14 du RGPD. Pour le développement de systèmes d'intelligence artificielle, quelques spécificités doivent être prises en compte.

1. Les informations relatives aux sources des données

L'information sur les sources présente des difficultés particulières. Deux cas sont à distinguer :

- **Si le nombre de sources que vous traitez est limité** : il faut, en principe, fournir l'identité précise des sources. Cela s'applique notamment au moissonnage sur un nombre limité de sites internet.
- **Si vous utilisez de nombreuses sources**, vous pouvez vous limiter à indiquer les catégories de sources, notamment les noms de quelques sources principales ou typiques. Cela s'applique au moissonnage sur des sources très nombreuses.

À noter : si un jeu de données ou un modèle d'IA soumis au RGPD est réutilisé, la CNIL recommande de fournir les moyens de contacter le **responsable de traitement** auprès duquel il a été récupéré, surtout si le jeu de données ou le modèle présente un risque important pour les personnes concernées.

2. L'information des personnes sur l'impossibilité de les identifier

Lorsque c'est le cas, vous devez informer les personnes de l'**impossibilité de les identifier, y compris pour répondre à leurs demandes d'exercice de droits** (article 11 du RGPD). La CNIL recommande, si c'est possible, d'indiquer aux personnes qui souhaitent exercer leurs droits, les informations complémentaires

qui pourraient aider à leur identification.

3. Le cas particulier des modèles d'IA soumis au RGPD

Lorsque votre modèle ou système d'IA est soumis au RGPD, la CNIL recommande de préciser **la nature du risque** lié à l'extraction de données personnelles de la base d'entraînement par la seule manipulation du modèle d'IA, les **mesures prises** afin de limiter ces risques et les mécanismes de recours si ces risques se réalisent.

- [Pour plus d'informations, voir la fiche n°9](#)
-

8e étape : Assurer l'exercice des droits

Le principe

Les personnes doivent pouvoir exercer leurs droits (droits d'accès, de rectification, d'effacement, à la limitation, à la portabilité) sur la base de données d'apprentissage et le modèle d'IA lui-même s'il n'est pas considéré comme anonyme.

Les solutions que vous devez mettre en œuvre pour garantir le respect des droits doivent être réalistes et proportionnées. Les difficultés propres aux systèmes d'IA (identification d'une personne physique dans une grande base de données et surtout dans un modèle, etc.) n'empêchent pas de trouver des réponses adaptées.

La CNIL recommande de préciser à la personne concernée la suite donnée à sa demande d'exercice de droits, surtout lorsque la répercussion de la modification sur la base de données n'est pas immédiate sur le **système d'IA** entraîné.

En pratique

Difficultés pour identifier la personne concernée

Si vous démontrez qu'**il n'est pas possible d'identifier la personne** concernée au sein de la base de données d'entraînement ou du modèle, vous devez l'indiquer en réponse à une demande d'exercice de droits. Vous n'avez pas à collecter de données personnelles supplémentaires uniquement pour être en capacité de répondre à l'exercice des droits.

Lorsque le RGPD s'applique au modèle, deux situations peuvent être distinguées :

- dans certains cas, la présence de données dans le modèle est évidente (certains modèles d'IA sont conçus pour fournir en sortie des données personnelles) ;
- dans d'autres, il vous est possible de démontrer **que vous ne pouvez pas identifier les personnes** au sein de votre modèle. L'état de l'art **actuel** ne permet pas, en général, d'identifier l'ensemble des données personnelles mémorisées par un modèle d'IA d'une personne en particulier.

Les personnes **peuvent toutefois fournir des données personnelles supplémentaires** afin d'aider à les retrouver dans la base de données ou dans le modèle (par exemple, une image ou un pseudonyme). La CNIL recommande d'anticiper ces difficultés et d'informer les personnes en leur indiquant les informations supplémentaires susceptibles de les aider dans leur recherche.

S'agissant plus particulièrement des modèles :

- si vous disposez encore du jeu d'entraînement, identifier la personne au sein de celui-ci est pertinent pour vérifier si des données sont susceptibles d'avoir été mémorisées par le modèle ;
- à défaut, la typologie des données utilisées vous permet d'anticiper les catégories susceptibles d'avoir été mémorisées et de faciliter les tentatives d'identification de la personne. Dans le cas des modèles d'IA générative, une **procédure interne d'interrogation** du modèle peut être mise en place.

S'agissant du droit d'accès

Dans le cas d'une base de données d'entraînement

Le droit d'accès permet à toute personne d'obtenir gratuitement une copie de l'ensemble des données traitées la concernant. Cette communication ne doit pas porter atteinte aux droits et libertés d'autrui (droits des autres personnes concernées, droits de propriété intellectuelle, secret des affaires du titulaire de la base de données, etc.).

Vous devez fournir **toutes les informations requises par le RGPD** lorsqu'une personne exerce son droit d'accès. Les personnes concernées doivent notamment :

- pouvoir **identifier les destinataires** précis de leurs données ;
- connaître **l'origine des données** lorsqu'elles ne sont pas collectées directement auprès d'elles (ex : courtiers de données).

Lorsque les données n'ont pas été collectées directement auprès des personnes concernées (par exemple en cas de transmission par un courtier en données), **le droit d'accès permet d'obtenir toute information « disponible » quant à leur source.**

Dans le cas d'un modèle d'IA soumis au RGPD

Deux cas peuvent se produire :

- Si vous identifiez la personne concernée et constatez que ses données ont été mémorisées par le modèle, vous devez le confirmer à la personne. Vous devez transmettre vos investigations à la personne concernée, incluant, pour des systèmes d'IA générative, les sorties contenant ses données personnelles.
- Si vous ne pouvez pas vérifier la présence de **mémorisation** mais pas non plus l'exclure (en raison des limites techniques et scientifiques actuelles), la CNIL vous recommande d'indiquer aux personnes qu'il n'est pas impossible que des données d'entraînement le concernant aient été mémorisées par le modèle. Dans ce cas, des **informations supplémentaires** sont à transmettre : les destinataires du modèle, sa

durée de conservation ou les critères permettant de la déterminer, les droits qui peuvent être exercés sur le modèle et sa provenance si vous n'en êtes pas le concepteur.

Droits de rectification, d'effacement et d'opposition

Les personnes disposent, sous certaines conditions, d'un droit de rectifier leurs données, de les faire effacer et de s'opposer à leur traitement pour des raisons qui leur sont propres que ce soit au sein de la base de données d'entraînement qu'au sein du modèle.

L'exercice des droits sur un modèle d'IA **n'est pas absolu**. La proportionnalité des mesures décrites ci-dessous dépend de la sensibilité des données et des risques que leur **régurgitation** ou divulgation ferait peser sur les personnes et de l'atteinte à la liberté d'entreprendre de l'organisme.

Par défaut, l'exercice des droits sur un modèle suppose son **réentraînement**, lorsque vous disposez toujours des données d'entraînement. Il peut être périodique afin de prendre en compte plusieurs demandes d'exercice de droit à la fois et se faire dans un délai allant jusqu'à **trois mois** en fonction de la complexité et du nombre de demandes. Les personnes concernées doivent être informées du délai prévu. Une version actualisée doit être transmise aux utilisateurs du modèle en imposant par voie contractuelle de n'utiliser qu'une version régulièrement à jour.

Dans le cas où vous démontrez que le réentraînement est disproportionné, il est recommandé de mettre en œuvre d'autres types de mesures comme des **filtres appliqués au système d'IA** qui encapsulent le modèle si vous démontrez que ces mesures sont suffisamment efficaces et robustes.

Il est recommandé, lorsque c'est possible, d'avoir recours à des règles générales permettant de détecter et pseudonymiser les données personnelles concernées, plutôt que d'utiliser une liste noire.

À noter : il reste recommandé d'anonymiser les données d'entraînement ou de s'assurer que son modèle d'IA est anonyme. Voir la section « Analyser le statut d'un modèle d'IA »

Enfin, le RGPD prévoit qu'un organisme notifie à chaque **destinataire** auquel les données personnelles ont été communiquées toute rectification ou effacement de données, à moins qu'une telle communication se révèle impossible ou exige des efforts disproportionnés. Le recours à des API ou à des mesures de traçabilité des téléchargements peuvent faciliter cette communication. Vous pouvez prévoir des obligations contractuelles de propagation de l'effet de l'exercice des droits pour les réutilisateurs, au moyen par exemple d'une licence de réutilisation.

Dérogations aux demandes d'exercices de droits

Vous pouvez **déroger** à l'exercice des droits lorsque la demande est manifestement infondée ou excessive, que l'exercice d'un ou plusieurs droits est exclu par le droit français ou européen ou que le traitement est effectué à des fins statistiques ou de recherche scientifique ou historique.

- [Pour plus d'informations, voir la fiche n°10](#)
-

9e étape : Sécuriser son système d'IA

Le principe

Le RGPD oblige les **responsables de traitement** à mettre en œuvre des mesures de sécurité : pilotage et dimensionnement des infrastructures, habilitations, gestion des sauvegardes ou encore sécurité physique sont concernés.

Les systèmes d'IA doivent faire l'objet d'une analyse de risque avec une attention toute particulière concernant leur développement logiciel, la constitution et l'administration de bases de données d'entraînement et leur maintenance.

La CNIL recommande de réaliser une AIPD pour documenter les mesures de sécurité (voir « réaliser une AIPD »).

OBJECTIFS DE SÉCURITÉ	MESURES DE SÉCURITÉ À ENVISAGER
Assurer la confidentialité et l'intégrité des données d'entraînement	☐ Vérifier la fiabilité, la qualité et l'intégrité des sources de données d'entraînement et de leurs annotations tout au long du cycle de vie ☐ Journaliser et gérer les versions des jeux de données ☐ Utiliser des données fictives ou de synthèse si possible (pour les tests de sécurité, l'intégration, certains audits, etc.) ☐ Chiffrer les sauvegardes et les communications ☐ Contrôler l'accès aux données lorsqu'elles ne sont pas diffusées en source ouverte ☐ Anonymiser ou pseudonymiser les données ☐ Cloisonner les jeux de données sensibles ☐ Prévenir les pertes de contrôle sur les données par des mesures organisationnelles

OBJECTIFS DE SÉCURITÉ	MESURES DE SÉCURITÉ À ENVISAGER
Garantir la performance et l'intégrité de son système d'IA	☐ Tenir compte de la protection des données dans les choix de conception du système, avec un effort de minimisation (Voir la section « Minimiser les données ») ☐ Utiliser des outils de développement, librairies, modèles pré-entraînés vérifiés. Une attention particulière doit être portée à la présence de portes dérobées (<i>backdoors</i>) dans le système ☐ Favoriser des formats d'importation et sauvegarde vérifiés (par exemple les <i>safetensors</i>) ☐ Recourir à un environnement de développement contrôlé, reproductible et facilement déployable ☐ Mettre en œuvre une procédure de développement et d'intégration continue ☐ Documenter la conception du système et son fonctionnement, les équipements matériels nécessaires, les mesures de protection implémentées, etc. ☐ Conduire des audits de sécurité en interne ou par des tiers en mettant notamment en œuvre des attaques courantes sur le système d'IA (Voir « Statut des systèmes d'IA »)
Anticiper le fonctionnement du système	☐ Porter à la connaissance de l'utilisateur les limitations du système en laboratoire et dans les contextes d'usage prévus ☐ Organiser la délivrance d'informations permettant à l'utilisateur d'interpréter les résultats ☐ Prévoir la possibilité de stopper le système ☐ Contrôler les sorties de l'IA par des filtres, de l'apprentissage par renforcement à partir de rétroaction humaine (RLHF), ou encore par des procédés de tatouage numérique (<i>watermarking</i>)

Mesures de sécurité générale des systèmes d'information

Les fonctionnalités des systèmes d'IA reposent généralement en grande partie sur les modèles utilisés, mais les risques les plus vraisemblables aujourd'hui portent sur les autres composants du système (comme les sauvegardes, interfaces et communications). Il peut ainsi être plus aisé pour l'attaquant d'exploiter une

vulnérabilité du logiciel pour accéder aux données d'entraînement que de mener une attaque par inférence d'appartenance.

Vous devez donc vous assurer de la bonne mise en œuvre des mesures de sécurité générale portant sur les systèmes d'information. Celles-ci et les risques auxquels elles permettent de faire face sont décrits dans le [guide de la CNIL sur la sécurité des données personnelles](#).

- [Pour plus d'informations, voir la fiche n°10](#)
-

10e étape : Analyser le statut d'un modèle d'IA

Le principe

Un modèle d'IA est une représentation statistique des caractéristiques de la base qui a servi à l'entraîner. De nombreux travaux académiques ont prouvé que, dans certains cas, cette représentation est suffisamment fine pour conduire à une divulgation de données d'entraînement. Comme cela est précisé dans [l'avis 28/2024 du CEPD](#), les modèles d'IA entraînés sur des données personnelles doivent la plupart du temps être considérés comme relevant du RGPD.

Pour déterminer si votre modèle est soumis ou non au RGPD (et qu'il peut donc être considéré anonyme), vous devez réaliser une analyse de son statut. Celle-ci vise à en extraire des données personnelles à l'aide de **moyens raisonnablement susceptibles d'être utilisés** (notamment tests d'attaques en réidentification).

En pratique

Quelles démarches suivre pour déterminer si le RGPD s'applique à un modèle ?

Le schéma ci-dessous précise la démarche pour déterminer si le RGPD s'applique à votre modèle ou si celui-ci peut être considéré anonyme.

Cliquer sur l'image pour consulter la version PDF

Quand conduire des tests d'attaques en réidentification sur un modèle ?

Un ensemble d'indice peut vous aider à caractériser la nécessité de conduire des attaques en réidentification des données d'entraînement sur votre modèle :

- **concernant les données d'entraînement** : si les données ont un caractère identifiant et précis, sont hétérogènes, rares ou dupliquées dans le jeu de données ;
- **concernant l'architecture du modèle** : s'il existe un rapport élevé entre le nombre de paramètres et le volume des données d'entraînement, un risque de surapprentissage ou en l'absence de garanties de confidentialité lors de l'apprentissage (**confidentialité différentielle** ou *differential privacy*, etc.) ;

- **concernant les fonctionnalités et usages du modèle** : si l'objectif est la reproduction de données similaires aux données d'entraînement (par exemple, la génération de contenu dans le cas des IA génératives) ou si des attaques en réidentification ont été menées avec succès sur des modèle similaires.

Quelles démarches suivre pour déterminer si le RGPD s'applique à un système ?

Si l'analyse du statut de votre modèle a conclu que celui-ci ne peut pas être considéré comme anonyme, vous pouvez atténuer la vraisemblance de réidentification des personnes en encapsulant celui-ci dans un **système d'IA** qui implémente des mesures robustes visant à en empêcher leur extraction.

Dans certains cas, ces mesures, qui doivent être éprouvées par la conduite systématique d'attaques sur le système, peuvent permettre de sortir l'utilisation du système du champ d'application du RGPD. Ces mesures peuvent inclure (sans qu'elles soient nécessairement suffisantes) :

- de rendre l'accès ou la récupération du modèle impossible,
- de mettre en place des restrictions d'accès au système,
- de limiter la précision ou de filtrer les sorties du modèle,
- des mesures de sécurité (voir section « Sécurité des systèmes d'IA »).

Le schéma ci-après précise la démarche que vous devez mettre en œuvre pour le déterminer :

Cliquer sur l'image pour consulter la version PDF

- [Pour plus d'informations, consulter la fiche n°13](#)
-

11e étape : Respecter les principes du RGPD lors de la phase d'annotation

Le principe

L'annotation consiste à attribuer une description, appelée « label » ou « étiquette », à chacune des données qui servira de « vérité de terrain » (*ground truth*) pour le modèle qui doit apprendre à traiter, classer, ou encore discriminer les données en fonction de ces informations.

En pratique

Mettre en œuvre le principe de minimisation

Votre annotation des données doit se limiter à ce qui est **nécessaire et pertinent** pour l'entraînement du modèle et la fonctionnalité prévue. Elle peut concerner des données indirectement liées à la fonctionnalité du **système d'IA** si l'impact sur la performance est prouvé (empiriquement ou théoriquement), ou suffisamment plausible. Elles peuvent aussi inclure des informations utiles à la mesure des performances, à la correction d'erreurs ou à l'évaluation de biais en donnant des éléments de contexte (météo, date, heure, etc.).

Ce principe est valable pour des annotations issues d'une collecte antérieure, d'un achat ou d'un téléchargement d'une base de données ouverte ou auprès d'un tiers. Si ce n'est pas techniquement possible, vous devez pouvoir justifier votre effort de recourir au jeu annoté le plus pertinent et supprimer les annotations non pertinentes.

Les annotations doivent également se limiter à ce qui est nécessaire à l'entraînement du modèle. Les recommandations dans la section « minimiser les données personnelles que j'utilise » sont donc applicables.

Garantir le principe d'exactitude

Les annotations que vous réalisez doivent être exactes, objectives et si possible à jour. La potentielle reproduction de ces annotations par le système peut sinon conduire à des sorties inexactes, dégradantes ou discriminatoires.

Annotation à partir de données sensibles

L'annotation « sensible » désigne une annotation contenant des données sensibles au sens de l'article 9 du RGPD, même si les données d'entraînement auxquelles elle se réfère ne le sont pas. L'annotation « sensible » est en principe interdite au titre de ce même article.

Vous pouvez toutefois mobiliser des exceptions, comme la conduite de projets de recherche en santé sur des données collectées lors de soins, au moyen d'un engagement de conformité à une méthodologie de référence (article 66 de la LIL) ou d'une demande d'autorisation accordée par la CNIL. Dans ce cas, vous devez prendre des mesures particulières :

- Annoter selon des critères objectifs et factuels (couleur de peau au sens de la couleur de pixel plutôt que l'origine ethnique, par exemple), se limiter aux informations contenues dans les données, sans interprétation, augmenter la sécurité des données annotées et s'interroger sur le risque de **régurgitation** et d'inférence.

À noter : le recours à des données sensibles est à éviter autant que possible et doit être remplacé si possible par des données de synthèse.

Information des personnes

En plus des informations obligatoires mentionnées dans la section « Informer les personnes », la CNIL recommande de transmettre, à titre de bonnes pratiques :

- Les objectifs de l'annotation (par exemple, identifier des personnes sur une image) ;
- Si ce n'est pas vous, l'organisme en charge de l'annotation, ainsi que les critères de responsabilité sociale respectés dans le cadre d'un contrat liant une personne en charge de l'annotation au **responsable de traitement**, notamment lorsque l'annotation porte sur **des données pouvant choquer** ;
- Les mesures de sécurité prises lors de la phase d'annotation.

Si l'annotation est susceptible d'avoir des conséquences sur la personne en cas de fuite de données ou que ses données représentent une part importante de la base de données d'entraînement, la CNIL recommande d'informer *a posteriori* les personnes du résultat de l'annotation lorsque c'est possible.

L'exercice des droits sur les annotations est détaillé dans la section « Assurer l'exercice des droits ».

- [Pour plus d'informations, voir la fiche n°11](#)
-

Focus : Réaliser une analyse d'impact sur la protection des données (AIPD)

Le principe

L'analyse d'impact sur la protection des données (AIPD) est une démarche qui vous permet de cartographier et d'évaluer les risques d'un traitement sur la protection des données personnelles et d'établir un plan d'action pour les réduire à un niveau acceptable. Elle va notamment vous conduire à définir les mesures de sécurité pour protéger les données.

En pratique

La réalisation d'une AIPD pour le développement de systèmes d'IA

Il est fortement recommandé de réaliser une AIPD pour le développement de votre système d'IA notamment lorsque deux des critères suivants sont remplis :

- des données sensibles sont collectées ;
- des données personnelles sont collectées à large échelle ;
- des données de personnes vulnérables (personnes mineures, en situation de handicap, etc.) sont collectées ;
- des ensembles de données sont croisés ou combinés ;
- de nouvelles solutions technologiques sont mises en œuvre ou une utilisation innovante est faite.

Par ailleurs, si des risques importants existent (par exemple : de mésusage des données, de **violation de données**, ou de discrimination), une AIPD doit être réalisée même si deux des critères précédents ne sont pas remplis.

Pour aider à réaliser une AIPD, [la CNIL met à disposition le logiciel open source PIA dédié](#).

Les critères de risque introduits par la proposition de règlement européen sur l'IA

La CNIL considère que, pour le développement des systèmes à haut risque visés par le règlement européen sur l'IA et impliquant des données personnelles, la réalisation d'une AIPD est en principe nécessaire.

À noter : la réalisation de l'AIPD pourra reposer sur la documentation exigée par le règlement sur l'IA sous réserve de comporter les éléments prévus par le RGPD (article 35

du RGPD).

Le périmètre de l'AIPD

Il existe deux types de situations pour le fournisseur d'un système d'IA, selon l'objectif du système d'IA (voir « définir un objectif (finalité) pour le système d'IA »).

- **Vous savez clairement quel sera l'usage opérationnel de votre système d'IA**

Il est recommandé de réaliser une AIPD générale pour l'ensemble du cycle de vie, qui comprend les phases de développement et de déploiement. Attention, si vous n'êtes pas l'utilisateur/déploieur du système d'IA, c'est ce dernier qui aura la responsabilité de réaliser l'AIPD pour la phase de déploiement (même s'il pourra s'appuyer sur le modèle d'AIPD que vous aurez proposé).

- **Si vous développez un système d'IA à usage général**

Vous ne pourrez réaliser une AIPD que sur la phase de développement. Cette AIPD doit être fournie aux utilisateurs de votre IA pour leur permettre de conduire leur propre analyse.

Les risques liés à l'IA à prendre en compte dans une AIPD

Les traitements de données personnelles reposant sur des systèmes d'IA présentent des risques spécifiques que vous devez prendre en compte :

- les risques liés à la confidentialité des données susceptibles d'être extraites depuis le système d'IA ;
- les risques pour les personnes concernées liés à des mésusages des données contenues dans la base d'apprentissage (par vos employés qui y ont accès ou en cas de violation de données) ;
- le risque d'une discrimination automatisée causée par un biais du système d'IA introduit lors du développement ;
- le risque de produire du contenu fictif erroné sur une personne réelle, notamment dans le cas des systèmes d'IA génératives ;
- le risque de prise de décision automatisée quand l'agent utilisant le système n'est pas en capacité de vérifier sa performance en conditions réelles ou de prendre une décision contraire à la sortie du système sans que cela ne lui porte préjudice (en raison d'une pression hiérarchique par exemple) ;
- le risque d'une perte de contrôle des utilisateurs sur leurs données accessibles en ligne ;
- les risques liés aux attaques connues spécifiques aux systèmes d'IA (par exemple, les attaques par empoisonnement des données) ;
- les risques éthiques systémiques et graves liés au déploiement du système.

Les mesures à prendre en fonction des résultats de l'AIPD

Une fois le niveau de risque déterminé, votre AIPD doit prévoir un ensemble de mesures visant à le réduire et à le maintenir à un niveau acceptable, par exemple :

- des mesures de sécurité (par exemple, le [chiffrement homomorphe](#) ou l'utilisation d'un environnement d'exécution sécurisé) ;
- des mesures de **minimisation**, (par exemple le recours à des données synthétiques) ;
- des mesures d'anonymisation ou de pseudonymisation (par exemple la confidentialité différentielle) ;
- des mesures de protection des données dès le développement (par exemple l'**apprentissage fédéré**) ;
- des mesures facilitant l'exercice des droits ou les recours pour les personnes (par exemple techniques de **désapprentissage machine**, mesures d'explicabilité et de traçabilité des sorties du systèmes d'IA, etc.) ;
- des mesures d'audit et de validation (par exemple des attaques fictives).

D'autres mesures, plus génériques, pourront également être appliquées : mesures organisationnelles (encadrement et limitation de l'accès aux bases de données d'apprentissage et pouvant permettre une modification du système d'IA, etc.), mesures de gouvernance (mise en place d'un comité éthique, etc.), mesures de traçabilité des actions ou documentation interne (charte information, etc.).

- [Pour plus d'informations, voir la fiche n°5](#)
-

Pour approfondir

- [Tous les contenus de la CNIL sur l'intelligence artificielle](#)
-